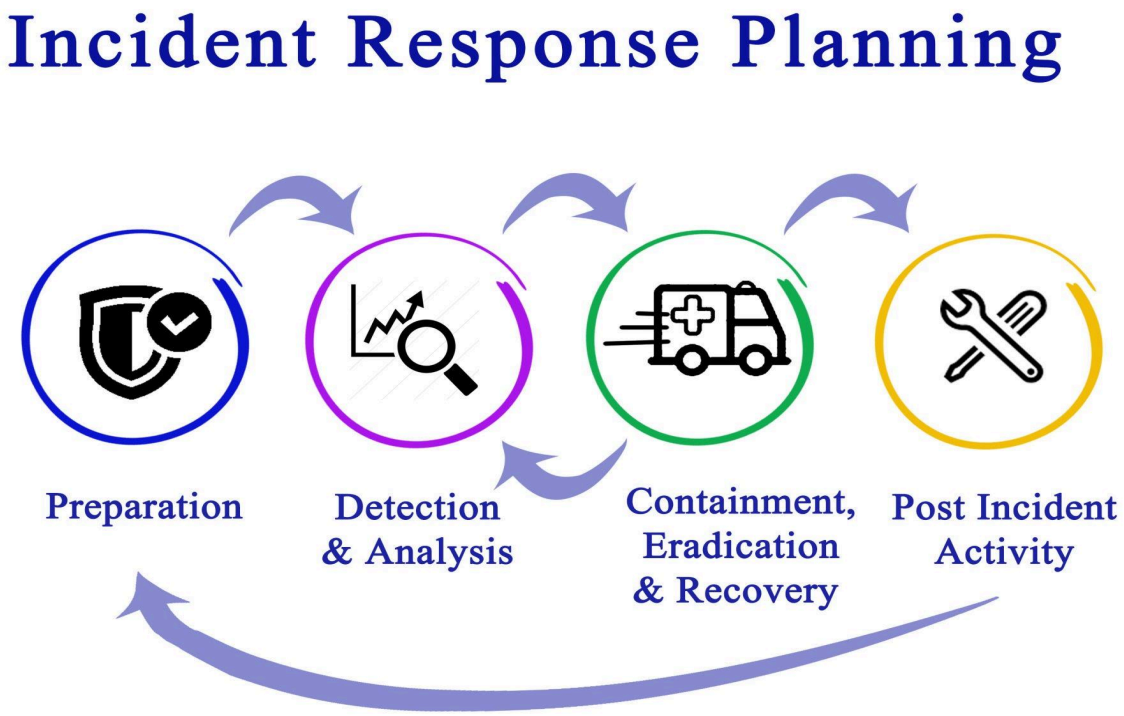
JEMSU Incident Response Playbook:

Account Compromise & Malvertising

Target Audience: Digital Advertising Team, IT Support, Executive Leadership **Objective:** Provide a rapid, step-by-step protocol to identify, contain, and recover from unauthorized access or malicious activity within the Google Ads Manager Account (MCC).

Disclaimer & Advisory Notice
This Incident Response Playbook represents my independent methodology and recommended best practices for mitigating an account compromise and malvertising event. It is not an official JEMSU document and does not necessarily reflect JEMSU's internal policies, existing security posture, or standard operating procedures. The containment and remediation steps outlined in this document are strictly advisory. They should only be executed by authorized personnel after a thorough review to ensure these actions align with the organization's technical environment, compliance requirements, and overall business interests.

Phase 1: Identification (Detecting the Threat)



Before you can stop an attack, the team needs to know what to look for. Any of the following triggers an immediate escalation to the **Containment Phase**.

- **Financial Anomalies:** Automated alerts indicating daily spend has spiked by 20% or more across the MCC within a short window.
- **Unauthorized Access Alerts:** Google Workspace notifications of new logins from unknown IP addresses, unrecognized devices, or unexpected Multi-Factor Authentication (MFA) prompts.
- **Campaign Modifications:** Reports from account managers of new, unrecognized campaigns being duplicated, or destination URLs being changed to unknown domains (malvertising payloads).
- **Access Changes:** Notifications that a new email address has been granted "Admin" or "Standard" access to the MCC or sub-accounts.

Phase 2: Immediate Containment (Stop the Bleeding)

Time is critical. The primary goal here is to stop financial loss and freeze the attacker out of the environment.

Step 1: The "Zero-Budget" or Pause Protocol

- **Action:** Immediately pause all suspicious campaigns. If the blast radius is too large to identify individual campaigns quickly, pause the entire affected sub-account or set the daily budget to $0.00.
- **Why:** This instantly stops the attacker from draining client funds while you investigate.

Step 2: Kill Active Sessions

- **Action:** The compromised user (e.g., the Director) must log into their Google Workspace account, navigate to **Security -> Your Devices**, and select **"Sign out"** on all active web and mobile sessions.
- **Why:** If the attacker used an Adversary-in-the-Middle (AiTM) attack to steal a session cookie, changing the password won't immediately kick them out. Invalidating the session cuts their connection.

Step 3: Lock Down IAM (Identity & Access Management)

- **Action:** A secondary, uncompromised Global Admin must navigate to the Google Ads MCC **Access and Security** tab. Immediately revoke access for any unrecognized email

addresses and temporarily downgrade the compromised user's permissions to "Read-Only" until their account is re-secured.

Phase 3: Eradication & Remediation (Securing the Perimeter)

Once the immediate threat is frozen, remove the vulnerability that allowed them in.

- **Credential Reset & Hardware Key Binding:** The compromised user must reset their password. Before regaining access to the MCC, their account must be bound to a physical FIDO2 security key (e.g., YubiKey) to prevent future session-hijacking.
- **Audit the "Change History":** Review the Change History log in Google Ads, filtering by the compromised user’s email. Export a list of every single modification (added keywords, changed URLs, duplicated ad groups) made during the breach window.
- **Endpoint Scan:** Have IT run a deep malware and endpoint detection scan on the compromised user's local machine to ensure the initial vector wasn't a local trojan or keylogger.

Phase 4: Recovery (Restoring Operations)

- **Revert Malicious Changes:** Using the exported Change History log, meticulously undo all unauthorized changes. Restore original landing page URLs and delete any malvertising campaigns.
- **Restore Budgets:** Once the account is fully audited and secured, unpause legitimate campaigns and restore standard daily budgets.
- **Initiate Fraud Claim:** Open a high-priority support ticket with Google Ads Support. Provide the Change History export and the exact timestamp of the unauthorized access to initiate the refund process for the fraudulent spend.